

=====

ASJ REALTY
COMMUNICATIONS SESSION AUTHENTICITY POLICY

=====

Document ID: POL-SC-015
Version: 1.0
Effective Date: July 8, 2026
Review Date: July 8, 2027
Owner: Sandra Okonkwo, IT Coordinator
Approved By: Anthony James, Principal Broker

=====

1. PURPOSE

This policy requires protection of the authenticity of communications sessions to prevent impersonation, replay, and man-in-the-middle attacks.

2. SESSION AUTHENTICITY MECHANISMS

2.1 Web / HTTPS Sessions

- All web sessions use TLS 1.2+ (mutual authentication via server certificates)
- HSTS (HTTP Strict Transport Security) ensures browsers remember to use HTTPS and reject certificate errors
- Certificate pinning: M365 enforces Microsoft root CA
- Invalid certificate errors: BLOCK (not bypass-able by users)

2.2 Email Authentication (Sender Authenticity)

- SPF record published for asjrealty.com
- DKIM signing enabled on all outbound email (M365)
- DMARC policy: p=reject (spoofed emails rejected)
- Inbound: M365 Defender checks SPF/DKIM/DMARC on receipt

2.3 Domain Authentication (Kerberos)

- Kerberos mutual authentication (client and server authenticate each other via KDC-issued tickets)
- Replay protection: Kerberos ticket timestamps + nonces

2.4 VPN / Remote Sessions

- Certificate-based mutual authentication for VPN (server presents certificate; client presents machine cert)
- IKEv2 provides authenticated key exchange (prevents MITM)

2.5 Azure AD / Cloud Sessions

- OAuth 2.0 with PKCE; tokens signed by Azure AD
- Token binding and session claims prevent token theft replay

=====

Approved: Anthony James 07/08/2026
Prepared: Sandra Okonkwo 07/06/2026

=====